Oxford Cambridge and RSA – style practice paper

GCSE (9–1) Computer Science

J277/01 Computer systems

Topic 1.4: Network security

Candidate forename		**Candidate surname**	
Centre number		**Candidate number**	

Practice questions in the style of OCR GCSE Computer Science (J277). Every question is original; the layout, command words, mark allocations and mark scheme follow the real exam format.

Time allowed	About 85 minutes (roughly 1 minute per mark)
Instructions	• Use black ink. HB pencil may be used for graphs and diagrams only. • Answer **all** the questions. • Write your answer to each question in the space provided. • Where the question asks you to write code or pseudocode, you may use any suitable high-level language or the OCR Reference Language; marks are for the logic, not exact syntax. • Do **not** use a calculator or any other electronic device unless told to.
Information	• The total mark for this paper is **76**. • The marks for each question are shown in brackets [ ]. • Quality of extended responses will be assessed in questions marked with an asterisk (*). • Where a question asks you to *state* or *give*, a short answer is enough; *describe* and *explain* need more detail.

Name: _____ Date: _____ Mark: _____ / 76

1 Networks face many threats.

(a) Tick (✓) **one** box to show which description matches **phishing**. **[1]**

☐	Trying every possible password until one works
☐	Sending emails pretending to be from a trusted organisation to trick people into giving personal information
☐	Flooding a server with requests so it cannot respond
☐	Software that copies itself and spreads between computers

(b) Describe what is meant by **malware**. **[2]**

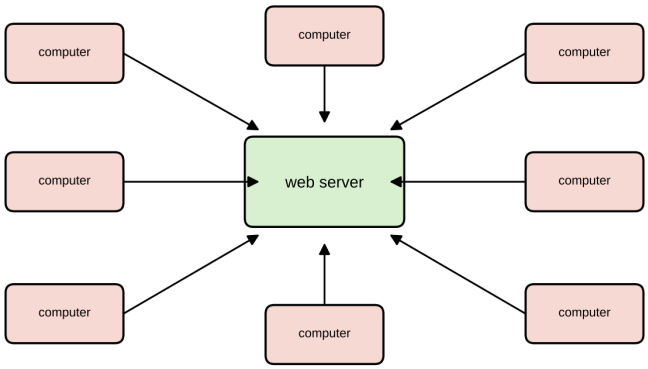
(c) Name **two** different types of malware. **[2]**

(d) Describe how **ransomware** affects a user. **[2]**

(e) Explain how a **brute force attack** is used to gain access to an account. **[2]**

(f) State **two** ways a user can make their password stronger. **[2]**

2 A web server is attacked. The diagram shows many computers sending requests to the server at the same time.



(a) Name this type of attack. **[1]**

(b) Explain how this attack stops genuine users from accessing the website. **[3]**

(c) State what is meant by a **botnet**. **[2]**

(d) Give **one** consequence for an online shop of its website being unavailable. **[1]**

3 Social engineering and data attacks.

(a) State what is meant by **social engineering**. **[2]**

(b) Draw **one** line from each method to its description. **[4]**

Method	Description
Phishing	Watching someone type their PIN or password
Blagging	Sending fake website addresses to redirect people to a copy of a real site
Shouldering	Pretending to be someone else, e.g. on the phone, to obtain information
Pharming	Fake emails asking the user to click a link or share details

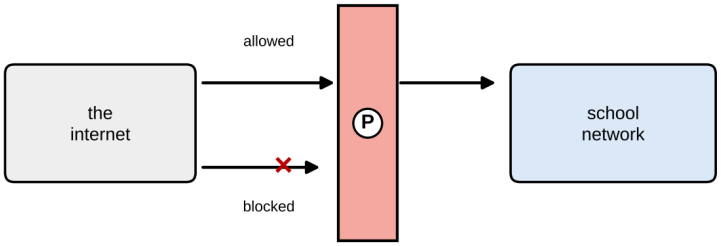
(c) A worker receives an email that looks like it is from the IT department asking for her password. Give **two** signs that the email could be phishing. **[2]**

(d) Explain what an **SQL injection** is and why it is a risk to a website that uses a database. **[3]**

(e) Describe **one** way a programmer can prevent SQL injection. **[1]**

(f) Explain what is meant by **data interception** and how encryption reduces the risk. **[3]**

4 The diagram shows a firewall, labelled **P**, between the internet and a school network.



(a) Describe what a **firewall** does. **[3]**

(b) Explain why the school should use a firewall **and** anti-malware software. **[3]**

(c) State **two** other methods of protecting a network from attack. **[2]**

5 A company wants to test the security of its network.

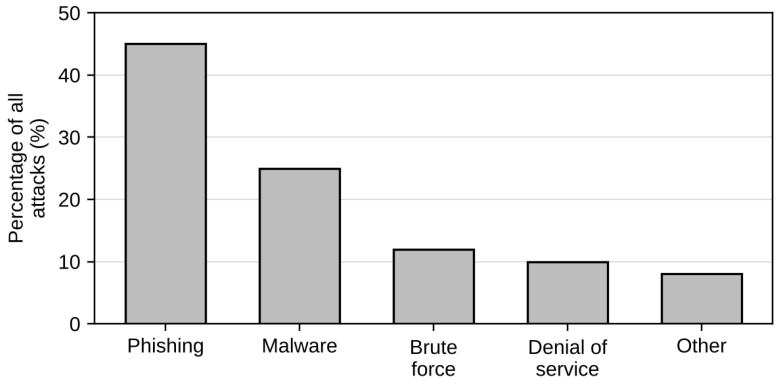
(a) State what is meant by **penetration testing**. **[2]**

(b) Explain why a company would use penetration testing. **[2]**

(c) Give **two** user access levels that could be set for the company's files and describe the difference. **[3]**

(d) A company stores customer details. Explain **two** ways the company could protect this data on its network. **[4]**

6 A security company recorded the types of attack made on businesses in one year. The bar chart shows the results.



(a) State the most common type of attack. **[1]**

(b) In the year 1200 attacks were recorded. Calculate how many were malware attacks. **[2]**

Answer _____ attacks

(c) Calculate how many **more** attacks were phishing than denial of service, as a percentage of all attacks. **[1]**

Answer _____ %

(d) Suggest **one** reason why phishing is the most common type of attack. **[1]**

(e) Describe how a company could reduce the risk of phishing attacks on its staff. **[3]**

7 Extended response questions.

(a) *A hospital stores patient records on a network. Discuss the threats to the network and the measures the hospital should take to protect the records. **[8]**

(b) *Explain how a hacker could use social engineering to gain access to a company's confidential files, and describe how the company could reduce this risk. **[8]**

END OF QUESTIONS

MARK SCHEME – Topic 1.4: Network security

How to use this mark scheme: mark your own work in a different colour. A bullet (•) in the Answer column is a separate marking point worth one mark unless stated. A slash (/) separates alternative answers that are equally acceptable. Words in brackets are not needed. **Accept** = acceptable; **Ignore** = neither credited nor penalised; **Do not accept** = contradicts or spoils the answer. For programming questions, any valid solution that works is acceptable and syntax errors are not penalised if the intent is clear. The code in the answers uses the OCR Reference Language style.

Question	Answer	Marks	Guidance
1(a)	Sending emails pretending to be from a trusted organisation to trick people into giving personal information	1 AO1 1.4.1	
1(b)	• software designed to harm / damage a computer or steal data ; • e.g. virus, worm, trojan, spyware, ransomware (any example) ;	2 AO1 1.4.1	
1(c)	• virus ; • worm ; trojan ; spyware ; ransomware ; adware ; keylogger ;	2 AO1 1.4.1	Any two.
1(d)	• encrypts / locks the user's files so they cannot be accessed ; • attacker demands payment to release / unlock the data ;	2 AO1 1.4.1	
1(e)	• the attacker uses software to try many / every possible password combination ; • until the correct one is found ;	2 AO1 1.4.1	
1(f)	• make it longer ; • include a mix of upper and lower case letters, numbers and symbols ; • avoid dictionary words / personal information ; • use a unique password for each account ;	2 AO2 1.4.2	Any two.
2(a)	distributed denial of service / DDoS (attack) ;	1 AO2 1.4.1	Accept: DoS.
2(b)	• a huge number of requests are sent to the server ; • the server cannot cope / becomes overloaded ; • so it slows down or crashes and genuine requests cannot be answered ;	3 AO2 1.4.1	
2(c)	• a network of infected computers ; • controlled remotely by an attacker without the owners' knowledge ;	2 AO1 1.4.1	
2(d)	• loss of sales / income ; • loss of customer trust / reputation damage ;	1 AO3 1.4.1	Any one.
3(a)	• manipulating / tricking people ; • into giving away confidential information or access (rather than breaking in using technology) ;	2 AO1 1.4.1	
3(b)	• phishing: emails / text messages tricking the user into revealing details ; • blagging: inventing a scenario / pretending to be someone to obtain information ; • shouldering (shoulder surfing): watching someone enter their PIN / password ; • pharming: redirecting users from a real website to a fake one ;	4 AO1 1.4.1	One mark for each correct match.

Question	Answer	Marks	Guidance
3(c)	• urgent / threatening language ; • spelling / grammar mistakes ; • sender address does not match the organisation ; • asks for personal information / password ; • generic greeting / suspicious link ;	2 AO3 1.4.1	Any two.
3(d)	• an attacker enters SQL code into an input box / form field ; • if the input is not validated, the code is run by the database ; • so the attacker may read, change or delete data ;	3 AO1 1.4.1	
3(e)	• validate / sanitise user input ; • use parameterised queries / prepared statements ;	1 AO2 1.4.2	Any one.
3(f)	• data is captured by a third party while it travels across a network ; • encryption scrambles the data ; • so it cannot be read without the key ;	3 AO2 1.4.1 / 1.4.2	
4(a)	• monitors / examines the data packets entering and leaving the network ; • compares them against a set of rules ; • blocks (or allows) the traffic that does not (or does) meet the rules ;	3 AO1 1.4.2	
4(b)	• firewall blocks unauthorised access / suspicious traffic ; • anti-malware scans files for / removes malicious software ; • malware may still enter through e.g. email attachments / USB which a firewall cannot always detect ;	3 AO2 1.4.2	
4(c)	• passwords / strong authentication ; • user access levels ; • encryption ; • penetration testing ; • physical security (locks / biometrics) ; • regular software updates ;	2 AO1 1.4.2	Any two.
5(a)	• an authorised attempt to hack into / attack the company's own network ; • to find weaknesses / vulnerabilities so they can be fixed ;	2 AO1 1.4.2	
5(b)	• finds vulnerabilities before real attackers can exploit them ; • so the company can fix them and reduce the risk of data loss / theft ;	2 AO2 1.4.2	
5(c)	• any two levels, e.g. read only ; • read and write / full access (edit and delete) ; • difference described: read only can only view whereas read-write can change the contents ;	3 AO2 1.4.2	Accept: admin / standard user / guest.
5(d)	• encrypt the data ; so that it cannot be read if stolen ; • use passwords / biometrics with access levels ; so only authorised staff can open it ; • install firewall / anti-malware ; to block attacks ; • regular backups ; so data can be recovered ;	4 AO2 1.4.2	Award 1 mark for each method and 1 mark for each linked explanation, up to 2 methods.
6(a)	phishing ;	1 AO2 1.4.1	
6(b)	• 25 ÷ 100 × 1200 ; • 300 ;	2 AO2 1.4.1	

Question	Answer	Marks	Guidance
6(c)	35 (%) ;	1 AO2 1.4.1	
6(d)	• cheap and easy to do / can target many people at once ; • relies on human error, which is hard to prevent with technology ;	1 AO3 1.4.1	Any one.
6(e)	• train / educate staff to recognise phishing emails ; • use email filters / spam filters ; • do not click on links or open unexpected attachments / verify sender ;	3 AO3 1.4.2	
7(a)	**Level 3 (high), 6–8 marks**: Thorough knowledge and understanding of the topic with detailed, accurate and relevant points. A balanced, well-structured answer reaching a justified conclusion where asked. Technical terms used correctly throughout. **Level 2 (mid), 3–5 marks**: Reasonable knowledge and understanding. Some relevant points made, but the answer lacks detail, balance or a clear structure in places. **Level 1 (low), 1–2 marks**: Basic knowledge. A few simple, mostly isolated points with little or no development or linking. **Level 0, 0 marks**: No response or no response worthy of credit. **Indicative content** (credit any other valid points): • threats: malware / ransomware could lock records; phishing and social engineering of staff to reveal passwords • brute force attacks on accounts; denial of service could make records unavailable; interception of data on wireless links • authorised users: strong passwords, user access levels so staff see only the records they need • technical: firewall, anti-malware, encryption of data stored and in transit, regular software updates / patches • regular backups so data can be recovered after ransomware / failure • penetration testing to find weaknesses; staff training on phishing and social engineering • physical security of servers / rooms; consequences: patient safety, legal fines (Data Protection Act), loss of trust • balanced judgement: no single measure is enough; a combination layered approach is best	8 AO1 / AO2 / AO3 1.4.1 / 1.4.2	

Question	Answer	Marks	Guidance
7(b)	**Level 3 (high), 6–8 marks**: Thorough knowledge and understanding of the topic with detailed, accurate and relevant points. A balanced, well-structured answer reaching a justified conclusion where asked. Technical terms used correctly throughout. **Level 2 (mid), 3–5 marks**: Reasonable knowledge and understanding. Some relevant points made, but the answer lacks detail, balance or a clear structure in places. **Level 1 (low), 1–2 marks**: Basic knowledge. A few simple, mostly isolated points with little or no development or linking. **Level 0, 0 marks**: No response or no response worthy of credit. **Indicative content** (credit any other valid points): • social engineering manipulates people rather than systems • phishing emails / fake login pages to trick staff into entering passwords • blagging: phoning pretending to be IT support / a manager to obtain details • shouldering: observing a password being entered; tailgating through a door • pharming: fake website redirecting a user to collect credentials • reduction: staff training; policies for verifying callers; email filters; do not share passwords • multi-factor authentication or biometrics so a stolen password alone is not enough • access levels limit what can be accessed if an account is compromised; physical measures such as locked doors and visitor passes	8 AO1 / AO2 1.4.1 / 1.4.2	

Where marks are lost in Topic 1.4

Use this page after marking. Tick the ones that cost you marks, then redo those questions closed-book.

- ☐ **Name the threat and say what it does:** 'phishing' alone earns nothing; 'emails pretending to be a trusted source to steal details' does.
- ☐ **Firewall:** checks packets against rules and blocks unauthorised traffic. It does not remove viruses; that is anti-malware.
- ☐ **Encryption** does not stop data being intercepted, it makes intercepted data unreadable.
- ☐ **DoS / DDoS:** flood of requests → server overloaded → genuine users cannot access. Mention **many computers** (botnet) for DDoS.
- ☐ **Prevention methods:** match the fix to the threat (training for phishing, validation for SQL injection, strong passwords for brute force).
- ☐ **Penetration testing** is *authorised* and finds weaknesses in order to fix them.
- ☐ **Data interpretation:** read the units. Percentages need × total ÷ 100.
- ☐ **Discuss questions:** threats, then measures, then a conclusion on how they work together.